# U.S. Office of Personnel Management, 2020

Structure

- **Executive Summary** – 1.5 pages long
- **Objectives, Scope, and Methodology** - clearly defined, uses NIST (and other standards)
- **Findings and Recommendations** – bulk of the document

# Executive Summary, 1.5 pages

- Short list of key findings
- Some are good, some are bad
- This may be all that someone reads

Identity, Credential, and Access Management (ICAM) – OPM is continuing to develop its agency ICAM strategy, and acknowledges a need to implement an ICAM program. However, OPM still does not have sufficient processes in place to manage contractors in its environment.
Data Protection and Privacy – OPM has implemented some controls related to data protection and privacy. However, there are still resource constraints within OPM's Office of Privacy and Information Management that limit its effectiveness.

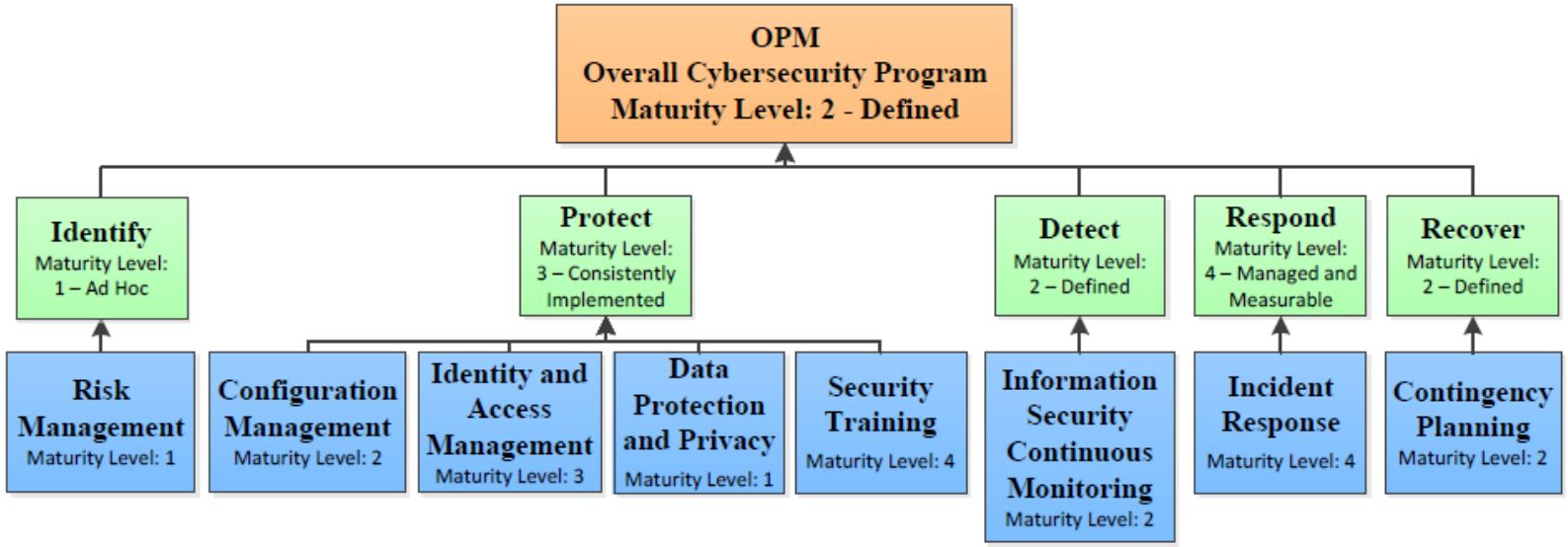
- Written at a high level

# Objectives, Scope, and Methodology, 3 pages

- Objectives and scope focus the assessment process
  - Can’t evaluate everything
  - In this case, scope is defined by the **Federal Information Security modernization Act (FISMA)**
- State methodology for credibility
  - They list 18 sources of criteria
  - Interviews and documents were used
  - Did NOT check the reliability of the documents

# Audit Findings and Recs, 54 pages

- List specific “metrics” with recommendations and responses
- Each metric is an aspect of security which they evaluate
- Metrics are defined by FISMA
- Present FISMA metric organization and assessment rubrics



# Assessment Rubrics

| Maturity Level | Maturity Level Description |
|---|---|
| **Level 1:** Ad-hoc | Policies, procedures, and strategy are not formalized; activities are performed in an ad-hoc, reactive manner. |
| **Level 2:** Defined | Policies, procedures, and strategy are formalized and documented but not consistently implemented. |
| **Level 3:** Consistently Implemented | Policies, procedures, and strategy are consistently implemented, but quantitative and qualitative effectiveness measures are lacking. |
| **Level 4:** Managed and Measureable | Quantitative and qualitative measures on the effectiveness of policies, procedures, and strategy are collected across the organization and used to assess them and make necessary changes. |
| **Level 5:** Optimized | Policies, procedures, and strategy are fully institutionalized, repeatable, self-generating, consistently implemented, and regularly updated based on a changing threat and technology landscape and business/mission needs. |

# Federal Information Security modernization Act (FISMA)

| Risk Management | | | |
|---|---|---|---|
| **1.** To what extent does the organization maintain a comprehensive and accurate ***inventory of its information systems*** (including cloud systems, public facing websites, and third-party systems), and system interconnections? | | | |
| **Criteria** | **Review Cycle** | **Maturity Level** | **Suggested Standard Source Evidence** |
| • NIST SP 800-53. Rev. 5: CA-3, PM-5, and CM-8<br>• NIST Cybersecurity Framework (CSF) ID.AM-1 – 4<br>• NIST SP 800-37, Rev. 2<br>• OMB A-130<br>• OMB 23-03<br>• FY 2023 CIO FISMA Metrics: 1.1 and 1.5 | Core | **Ad Hoc**<br>The organization has not defined its policies, procedures, and processes for developing and maintaining a comprehensive and accurate inventory of its information systems and system interconnections. | |
| | | **Defined**<br>The organization has defined its policies, procedures, and processes for developing and maintaining a comprehensive and accurate inventory of its information systems and system interconnections. | • Directives, policies, procedures, standards, strategies, and/or standards associated with the system registration and inventory process;<br>• System interconnect inventory processes and procedures;<br>• Information Security Program policies and procedures;<br>• Ongoing authorization policies and procedures. |
| | | **Consistently Implemented**<br>The organization consistently implements its policies, procedures, and processes to maintain a comprehensive and accurate inventory of its information systems (including cloud systems, | • Organization-wide information systems inventory, including contractor operated information systems; |

# Metrics

Each metric has the following:

- Number and name
- Rubric evaluation score
- A few paragraphs description of findings
- Recommendations, 1 or more

Each recommendation has the following:

- Statement of the recommendation
- Response from the OPM organization
- Rebuttal comment from the evaluators

**Metric 1 – Inventory of Major Systems and System Interconnections**

*FY2020 Maturity Level: 1 – Ad-hoc.* OPM has policies and procedures for maintaining an inventory of information systems. These require an interconnection service agreement or memoranda of understanding to be established for system interconnections. OPM operates a centrally maintained tool for managing its system inventory and information.

**Recommendation 1 (Rolled forward from 2018)**

We recommend that OPM improve the policies and procedures for defining system boundaries and classifying the systems in its environment.

***OPM Response:***

***"We do not concur with the recommendation.***

**OIG Comment:**

During fieldwork discussions in FY 2020 Q3, OPM indicated that the pilot program was still in progress.

# City of Fort Worth, 2020 (12 pages total)

Structure

- **Executive Summary** – 1 page long
- **Background** – Useless definition of security (1 page)
- **Objectives, Scope, and Methodology** - uses NIST (and other standards), 1 page
- **Audit Results –** findings, without recommendations, 1.5 pages
- **Detailed Audit Findings** – elaboration about each finding, with recommendations and auditee response

# Executive Summary vs. Audit Results

- Audit results are a 1.5 page version of the executive summary
- Executive summary is less specific

Continuity of Operations (COOP) Plans – The City has departmental COOP plans. However, a formal process for the management and maintenance of those plans did not exist. COOP plans existed for most, but not all, departments. In some instances, departmental COOP plans had inaccurate information and/or were outdated.

Six departmental Continuity of Operations (COOP) plans contained incorrect contact (primary and alternate) information, and 10 department plans contained no information regarding dates of last review/update.

# Detailed Audit Findings

- **Problem**
  - A problem is identified and described in a few paragraphs
- **Recommendation**
  - A solution is recommended
  - Not really optional
- **Auditee's Response**
  - Auditee describes that they either have fixed the problem or will fix it
  - They give a date by which it will be fixed

# Example Problem

- **1. Continuity of Operations (COOP) Plans** did not exist for each City department, and some existing COOP Plans were not up-to-date.

We reviewed the current CFW Continuity of Operations plans for each department, and noted the following:

| Department | Existing Plan | Departmental Contact Information | Date Last Updated Known / Unknown |
|---|---|---|---|
| Aviation | Yes | Incorrect/Missing | Known |
| City Secretary's Office | Yes | Incorrect/Missing | Unknown |
| Code Compliance | Yes | Correct | Unknown |
| Communications & Public Engagement | Yes | Correct | Known |
| Development Services | Yes | Correct | Known |

# Recommendation and Response

- **Recommendation 1A:** *The Fire Chief, through the Office of Emergency Management's Emergency Operations Manager, should ensure that all CFW departments provide current and up-to-date COOP plan documents for their respective operations.*
- **Auditee's Response:** Concur. The Fire Chief in association with the Emergency Operations Coordinator has confirmed that COOP plans have been submitted by all CFW departments. Those plans can be accessed on the City of Fort Worth's JEOC Sharepoint site at: https://fortworthtexas.sharepoint.com/sites/JEOC/SitePages/Continuity-of-Operations-(COOP).aspx.
  - **Responsibility:** Fire – Office of Emergency Management (OEM)
  - **Target Implementation Date:** Completed
  - **Applicable Department Head:** James Davis, Fire Chief
  - **Applicable Assistant City Manager:** Valerie Washington